A-I Vocational Training Institute of Cyber Security (AIOVTIC)

A Concise Script on Network Security and Protocols.

Compiled by: Ayan Nicholas.

Introduction

The digital threat landscape continues to evolve as bad actors design new ways of attacking networks. This makes network security protocols more important than ever because they help secure the lines of communication that power your business operations and revenue stream.

Using network security protocols as a foundation, you can build a scalable, reliable information system that supports the talent within your organization.

What is a network?

A network is a group of two or more connected computing devices. Usually all devices in the network are connected to a central hub — for instance, a router. A network can also include subnetworks, or smaller subdivisions of the network. Subnetworking is how very large networks, such as those provided by ISPs, are able to manage thousands of IP addresses and connected devices.

Think of the Internet as a network of networks: computers are connected to each other within networks, and these networks connect to other networks. This enables these computers to connect with other computers both near and far.

What Is Network Security?

Network security is the protection of the underlying networking infrastructure from unauthorized access, misuse, or theft. It is the practice of protecting corporate networks from intrusions and data

breaches. It involves creating a secure infrastructure for devices, applications, users, and applications to work in a secure manner.

How does network security work?

Network security combines multiple layers of defenses at the edge and in the network. Each network security layer implements policies and controls. Authorized users gain access to network resources, but malicious actors are blocked from carrying out exploits and threats.
How do I benefit from network security?

Digitization has transformed our world. How we live, work, play, and learn have all changed. Every organization that wants to deliver the services that customers and employees demand must protect its network. Network security also helps you protect proprietary information from attack. Ultimately it protects your reputation.

Types of network security

Firewalls

A firewall is a network security device that monitors incoming and outgoing network traffic and decides whether to allow or block specific traffic based on a defined set of security rules.
Workload security

Workload security protects workloads moving across different cloud and hybrid environments. These distributed workloads have larger attack

surfaces, which must be secured without affecting the agility of the business.

NetWORK security

NetWORK security is Cisco's vision for simplifying network, workload, and multicloud security by delivering unified security controls to dynamic environments.

Network segmentation

Software-defined segmentation puts network traffic into different classifications and makes enforcing security policies easier. Ideally, the classifications are based on endpoint identity, not mere IP addresses. You can assign access rights based on role, location, and more so that the right level of access is given to the right people and suspicious devices are contained and remediated.

VPN

A virtual private network encrypts the connection from an endpoint to a network, often over the internet. Typically, a remote-access VPN uses IPsec or Secure Sockets Layer to authenticate the communication between device and network.

Access control

Not every user should have access to your network. To keep out potential attackers, you need to recognize each user and each device.

Then you can enforce your security policies. You can block noncompliant endpoint devices or give them only limited access. This process is network access control (NAC).

Anti-virus and anti-malware software

"Malware," short for "malicious software," includes viruses, worms, Trojans, ransomware, and spyware. Sometimes malware will infect a network but lie dormant for days or even weeks. The best antimalware programs not only scan for malware upon entry, but also continuously track files afterward to find anomalies, remove malware, and fix damage.

Application security

Any software you use to run your business needs to be protected, whether your IT staff builds it or whether you buy it. Unfortunately, any application may contain holes, or vulnerabilities, that attackers can use to infiltrate your network. Application security encompasses the hardware, software, and processes you use to close those holes.

Behavioral analytics

To detect abnormal network behavior, you must know what normal behavior looks like. Behavioral analytics tools automatically discern activities that deviate from the norm. Your security team can then better identify indicators of compromise that pose a potential problem and quickly remediate threats.

Cloud security

Cloud security is a broad set of technologies, policies, and applications applied to defend online IP, services, applications, and other imperative data. It helps you better manage your security by shielding users against threats anywhere they access the internet and securing your data and applications in the cloud.

Data loss prevention

Organizations must make sure that their staff does not send sensitive information outside the network. Data loss prevention, or DLP, technologies can stop people from uploading, forwarding, or even printing critical information in an unsafe manner.

Email security

Email gateways are the number one threat vector for a security breach. Attackers use personal information and social engineering tactics to build sophisticated phishing campaigns to deceive recipients and send them to sites serving up malware. An email security application blocks incoming attacks and controls outbound messages to prevent the loss of sensitive data.

Industrial network security

As you are digitizing your industrial operations, the deeper integration between IT, cloud, and industrial networks is exposing your Industrial

Control Systems (ICS) to cyberthreats. You need full visibility into your OT security posture to segment the industrial network, and feed IT security tools with rich details on OT devices and behaviors.

Mobile device security

Cybercriminals are increasingly targeting mobile devices and apps. Within the next three years, 90 percent of IT organizations may support corporate applications on personal mobile devices. Of course, you need to control which devices can access your network. You will also need to configure their connections to keep network traffic private.

Security information and event management

SIEM products pull together the information that your security staff needs to identify and respond to threats. These products come in various forms, including physical and virtual appliances and server software.

Web security

A web security solution will control your staff's web use, block web-based threats, and deny access to malicious websites. It will protect your web gateway on site or in the cloud. "Web security" also refers to the steps you take to protect your own website.

Wireless security

Wireless networks are not as secure as wired ones. Without stringent security measures, installing a wireless LAN can be like putting Ethernet ports everywhere, including the parking lot. To prevent an exploit from taking hold, you need products specifically designed to protect a wireless network.

What protocols are used at the network layer?

A protocol is an agreed-upon way of formatting data so that two or more devices are able to communicate with and understand each other. A number of different protocols make connections, testing, routing, and encryption possible at the network layer, including:

- IP, IPsec, ICMP, IGMP, GRE

What Are Network Security Protocols?

Network security protocols are network protocols that ensure the integrity and security of data transmitted across network connections. The specific network security protocol used depends on the type of protected data and network connection. Each protocol defines the techniques and procedures required to protect the network data from unauthorized or malicious attempts to read or exfiltrate information.

The role of protocols in cybersecurity

Protocols are a strong line of defense in the battle against hackers because they prevent people from infiltrating, corrupting, stealing or taking advantage of your communication system. For instance, attackers would have difficulty wiretapping or listening in on communications because encryption would result in them only getting a jumbled set of nonsensical characters.

Also, by setting up your security protocols correctly, you can prevent denial of service attacks. For example, you can use IPsec to require that each entity that interacts with your network goes through an authentication procedure. This would prevent hackers from randomly sending thousands or millions of requests to a server in a denial-of-service attack because they wouldn't be able to access the server in the first place.

In addition, many phishing attacks use fake websites to trick people into entering sensitive information. You can leverage SSL/TLS Digital certificates to authenticate the validity of a site an employee may be trying to visit, which would prevent them from going to one a hacker built that only appears to be legitimate.

Protocols also play a pivotal role in cybersecurity frameworks. These frameworks provide guidance for security engineers and their teams to

help make the network environments they work with as safe and reliable as possible.

Protocols intersect with many facets of cybersecurity frameworks because the frameworks use them as tools to keep communications and data safe. Those who design cybersecurity frameworks often piece together various security protocols like components of a machine to keep the networks that use the frameworks running smoothly.

Without network security protocols, framework designers may have to code their own solutions instead of using proven, effective technologies.

What is the network layer?

Network-to-network connections are what make the Internet possible. The "network layer" is the part of the Internet communications process where these connections occur, by sending packets of data back and forth between different networks.

In the 7-layer, the network layer is layer 3. The Internet Protocol (IP) is one of the main protocols used at this layer, along with several other protocols for routing, testing, and encryption.

Suppose Bob and Alice are connected to the same local area network (LAN), and Bob wants to send Alice a message. Because Bob is on the

same network as Alice, he could send it directly to her computer across the network. However, if Alice is instead on a different LAN several miles away, Bob's message will have to be addressed and sent to Alice's network before it can reach her computer, which is a network layer process.

What is the OSI model?

The Open Systems Interconnection (OSI) Model is a description of how the Internet works. It breaks down the functions involved in sending data over the Internet into seven layers. Each layer has some function that prepares the data to be sent over wires, cables, and radio waves as a series of bits.

> It is important to keep in mind that the OSI model is an abstract conceptualization of the processes that make the Internet work, and interpreting and applying the model to the real-world Internet is sometimes a subjective exercise.
>
> The OSI model is useful for helping people talk about networking equipment and protocols, determining which protocols are used by which software and hardware, and showing roughly how the Internet works. But it is not a rigid step-by-step definition of how Internet connections always function.

The OSI Network Model

Open Systems Interconnection (OSI) is a reference model for how applications communicate over networks. It shows how each layer of communication is built on top of the other, from the physical wiring to the applications that attempt to communicate with other devices over the network.

The OSI is a reference model that guides technology vendors on the design of interoperable software and hardware, providing a clear framework that describes the capabilities of a network or communications system. For security teams, the OSI model helps understand which layers of the network they need to defend, where specific security threats could strike, and how to prevent and mitigate them.

The OSI Model contains the following layers:

- **Layer 1—Physical Layer**—the physical cable or wireless connection between network nodes. Packets are converted into electrical, radio, or optical pulses and transmitted as bits (the smallest possible units of information) over wires, radio waves, or cables.

- **Layer 2—Data Link Layer**—creates and terminates connections, breaks up packets into frames and transmits them from source to destination. Handles communications

between devices on the same network. If layer 3 is like the address on a piece of mail, then layer 2 is like indicating the office number or apartment number at that address. Ethernet is the protocol most used here.

- **Layer 3—Network Layer**—breaks up segments into network packets, and reassembles them upon receipt, and routes packets using an optimal path on the physical network. Handles the routing and sending of data between different networks. The most important protocols at this layer are IP and ICMP.

- **Layer 4—Transport Layer**—responsible for reassembling the segments on the receiving end, turning it into data that can be used by the session layer. Provides the means for transmitting data between the two connected parties, as well as controlling the quality of service. The main protocols used here are TCP and UDP.

- **Layer 5—Session Layer**—creates communication channels, called sessions, between devices. Keeps sessions open during data transfer and closing them when it ends. Controls connections between computers (this can also be handled at layer 4 by the TCP protocol).

- **Layer 6—Presentation Layer**—prepares data for the application layer, defining how two devices should encode, encrypt, and compress data to ensure it is received correctly. Data is translated into a form the application can accept. Some authorities consider HTTPS encryption and decryption to take place at this layer.

- **Layer 7—Application Layer**—used by end-user software like web browsers and email clients. Sends and receives information that is meaningful for end-users using protocols like HTTP, FTP, and DNS. Data generated by and usable by software applications. The main protocol used at this layer is HTTP.

Types of Network Security Protocols

Following are some of the most common network security protocols. They are arranged by the network layer at which they operate, from bottom to top.

Internet Protocol Security (IPsec) Protocol—OSI Layer 3

IPsec is a protocol and algorithm suite that secures data transferred over public networks like the Internet. The Internet Engineering Task Force (IETF) released the IPsec protocols in the 1990s. They

encrypt and authenticate network packets to provide IP layer security.

IPsec originally contained the ESP and AH protocols. Encapsulating Security Payload (ESP) encrypts data and provides authentication, while Authentication Header (AH) offers anti-replay capabilities and protects data integrity. The suite has since expanded to include the Internet Key Exchange (IKE) protocol, which provides shared keys establishing security associations (SAs). These enable encryption and decryption via a firewall or router.

IPsec can protect sensitive data and VPNs, providing tunneling to encrypt data transfers. It can encrypt data at the application layer and enables authentication without encryption.

SSL and TLS—OSI Layer 5

The Secure Sockets Layer (SSL) protocol encrypts data, authenticates data origins, and ensures message integrity. It uses X.509 certificates for client and server authentication. SSL authenticates the server with a handshake, negotiating security session parameters and generating session keys. It can then securely transmit the data by authenticating its origin.

SSL sessions use cryptographic algorithms similar to the algorithms used by the client and server (determined during the handshake).

Servers may support encryption with algorithms like AES and Triple DES.

X.509 server certificates are a requirement for SSL, enabling the client to validate the server. SSL can also use X.509 client certificates for authentication. These certificates must be signed by a trusted certificate authority in the server's keyring.

Transport Layer Security (TLS) is an SSL-based protocol defined by the IETF (SSL is not).

Datagram Transport Layer Security (DTLS)—OSI Layer 5

DTLS is a datagram communication security protocol based on TLS. It does not guarantee message delivery or that messages arrive in order. DTLS introduces the advantages of datagram protocols, including lower latency and reduced overhead.

Kerberos Protocol—OSI Layer 7

Kerberos is a service request authentication protocol for untrusted networks like the public Internet. It authenticates requests between trusted hosts, offering built-in Windows, Mac, and Linux operating system support.

Windows uses Kerberos as its default authentication protocol and a key component of services like Active Directory (AD). Broadband

service providers use it to authenticate set-top boxes and cable modems accessing their networks.

Systems, services, and users, only need to trust the KDC when using Kerberos. KDC offers authentication and grants tickets to enable nodes to authenticate each other. Kerberos uses shared secret cryptography to authenticate packets and protect them during transmission.

Simple Network Management Protocol (SNMP)—OSI Layer 7

SNMP is a network device management and monitoring protocol that works at the application layer. It can secure devices on LANs or WANs. SNMP provides a shared language to allow devices like servers and routers to communicate via a network management system. SNMP is an original part of the Internet protocol suite defined by the IETF.

Components of the SNMP architecture include a manager, an agent, and a management information base (MIB). The manager is the client, the agent is the server, and the MIB is the database. The SNMP agent responds to the manager's requests using the MIB. While SNMP is widely available, administrators must adjust the default settings to enable communication between the agents and the network management system to implement the protocol.

With the introduction of SNMPv3 in in 2004, the SNMP protocol gained three important security features: encryption of packets to prevent eavesdropping, integrity checks to ensure packets were not been tampered in transit, and authentication to verify that communications come from a known source.

HTTP and HTTPS—OSI Layer 7

HTTP is an application protocol that specifies rules for web file transfers. Users indirectly use HTTP when they open their web browser. It runs on top of the Internet protocol suite.

HTTPS is the secure version of HTTP, securing the communication between browsers and websites. It helps prevent DNS spoofing and man-in-the-middle attacks, which is important for websites that transmit or receive sensitive information. All websites requiring user logins or handling financial transactions are attractive data theft targets and should be using HTTPS.

HTTPS runs over the SSL or TLS protocol using public keys to enable shared data encryption. HTTP uses port 80 by default, while HTTPS uses port 443 for secure transfers. With HTTPS, the server and browser must establish the communication parameters before initiating data transfers.

What happens at the network layer?

Anything that has to do with inter-network connections takes place at the network layer. This includes setting up the routes for data packets to take, checking to see if a server in another network is up and running, and addressing and receiving IP packets from other networks. This last process is perhaps the most important, as the vast majority of Internet traffic is sent over IP.

What is a packet?

All data sent over the Internet is broken down into smaller chunks called "packets." When Bob sends Alice a message, for instance, his message is broken down into smaller pieces and then reassembled on Alice's computer. A packet has two parts: the header, which contains information about the packet itself, and the body, which is the actual data being sent.

At the network layer, networking software attaches a header to each packet when the packet is sent out over the Internet, and on the other end, networking software can use the header to understand how to handle the packet.

A header contains information about the content, source, and destination of each packet (somewhat like stamping an envelope with a destination and return address). For example, an IP header contains the

destination IP address of each packet, the total size of the packet, an indication of whether or not the packet has been fragmented (broken up into still smaller pieces) in transit, and a count of how many networks the packet has traveled through.

OSI model vs. TCP/IP model

The TCP/IP model is an alternative model of how the Internet works. It divides the processes involved into four layers instead of seven. Some would argue that the TCP/IP model better reflects the way the Internet functions today, but the OSI model is still widely referenced for understanding the Internet, and both models have their strengths and weaknesses.

In the TCP/IP model, the four layers are:

- **4. Application layer:** This corresponds, approximately, to layer 7 in the OSI model.
- **3. Transport layer:** Corresponds to layer 4 in the OSI model.
- **2. Internet layer:** Corresponds to layer 3 in the OSI model.

- **1. Network access layer:** Combines the processes of layers 1 and 2 in the OSI model.

But where are OSI layers 5 and 6 in the TCP/IP model? Some sources hold that the processes at OSI layers 5 and 6 either are no longer necessary in the modern Internet, or actually belong to layers 7 and 4 (represented by layers 4 and 3 in the TCP/IP model).

For instance, since the TCP protocol opens and maintains sessions at OSI layer 4, one could consider OSI layer 5 (the "session" layer) to be unnecessary — and it is not represented in the TCP/IP model. Additionally, HTTPS encryption and decryption can be considered an application layer (OSI layer 7 or TCP/IP layer 4) process instead of a presentation layer (OSI layer 6) process.

What is the difference between the 'network' layer and the 'Internet' layer?

In the TCP/IP model, there is no "network" layer. The OSI model network layer roughly corresponds to the TCP/IP model Internet layer. In the OSI model the network layer is layer 3; in the TCP/IP model the Internet layer is layer 2.

In other words, the network layer and the Internet layer are basically the same thing, but they come from different models of how the Internet works.

How does Cloudflare protect the network layer?

Because they are exposed to the rest of the Internet, network layer infrastructure is vulnerable to external attacks, especially distributed denial-of-service (DDoS) attacks. Routers, switches, and other network interfaces can all be overwhelmed or compromised by malicious network traffic, and almost any of the above network protocols can be used in an attack.

Cloudflare Magic Transit protects networking infrastructure using the same technology that keeps millions of web properties up and running in the face of vulnerability exploits and DDoS attacks. It extends the protection of Cloudflare to on-premise and data center networks, keeping organizations secure from network layer attacks

Network Security Threats and Vulnerabilities

Network security protects the boundary between external and internal networks, keeping sensitive data and vital applications safe from

unauthorized outsiders. Robust network security infrastructure is essential for any company's security posture. But to create a functional security setup, it's vital to understand why networks are vulnerable and the many threats they face.

Common network security threats include social engineering attacks aimed at stealing user credentials, denial of service (DoS) attacks that can overwhelm network resources, and malware used by attackers to establish a persistent hold on the network.

What is a network security threat?

In a modern IT environment, network threats can originate from automated mechanisms like bots, sophisticated attacks known as advanced persistent threats (APT), malicious insiders, and third party vendors whose systems were compromised by attackers.

Network security **vulnerabilities** are weak points in physical devices or software which present an opportunity for cyber attackers. Weaknesses could range from poor server surveillance and physical protection to inadequate operating system and antivirus updates.

Network security **threats** are specific attack methods that exploit those vulnerabilities. There are multiple ways to launch such attacks. All of them should be part of network security policies.

The major types of network security threats

Malware

Malware, or malicious software, is software designed to damage target systems. Around 30% of computers in the USA are thought to be infected with malware, so the problem is significant.
Most malware attacks result from zero-day exploits and unpatched applications or operating systems. But phishing, man-in-the-middle, or insecure file sharing can also be to blame.
Malware is an umbrella term for several sub-varieties of cyber threats, and can have various effects. Some versions cause system slowdown. Others freeze systems, while some malware facilitates data exfiltration.

Malware can spread across computer systems, and can be used to compromise a device or cause damage to data and systems. Malware is commonly used by attackers to establish and deepen their hold on compromised systems in a corporate network. Its primary distribution vectors are email, malicious links, and compromised websites.

1. Keyloggers

Keyloggers log the keystrokes of infected devices. Generally created to steal login credentials and personal information, they usually spread via email attachments or downloadable files on malicious websites.

Some keyloggers also take regular screenshots or hijack the device's camera. In that case, virtual meetings can be compromised, along with other sensitive information.

Keyloggers can be superficially resident and easy to diagnose but can also be installed via rootkits deep inside a device at the kernel level. Deeper-rooted keyloggers are uncommon but most concerning. Simpler versions tend to be vulnerable to standard anti-malware scanners.

2. Trojans

Trojans take their name from the "Trojan Horse" which enabled ancient Greek soldiers to conquer Troy while the residents slept.

Trojan agents are engineered to appear legitimate, just like the horse. Trojan victims download apps as usual. When opened, infected apps automatically seed malware, leading to various worrying consequences. For instance, banking Trojans harvest financial login details. Backdoor Trojans create routes for attackers to steal information from devices. Mailfinders scan for email contact details, while downloaders constantly download and seed new forms of malware.

The encouraging news about Trojans is that they cannot replicate autonomously. Additionally, if malware scanners find them, they can usually neutralize them quickly.

3. Ransomware

An especially damaging form of malware is ransomware, which encrypts data, making it unusable to its owners. Ransomware holds users to ransom, freezing devices or apps and demanding a specific action before restoring system functionality**.** The ransom tends to involve payment in standard currency or crypto-currency.

The cost of ransomware can be crippling. Downtime due to ransomware attacks cost US businesses $159 billion in 2021, with payment demands averaging $7.9 billion.

Payment is also no guarantee that attackers will restore app or data access. 24% of organizations that chose to pay attackers did not recover their data.

As with other malware varieties, ransomware spreads via emails, infected websites, and app downloads.

4. Adware

Adware **forces victims to see pop-up ads** whether they want to or not. Relatively harmless compared to other threats, Adware can still be a considerable drain on system resources and a sign that systems are insecure.

5. Spyware

Unlike ransomware, spyware leaves few traces. It keeps a low profile, hiding from anti-malware scanners while **gathering potentially useful information**.

This information could include device profiles, location data, keystrokes, emails, camera images, contacts, or financial data. Sometimes, information gathered feeds back to adware networks, determining which pop-ups appear. In others, data feeds straight to criminals for sale on the Dark Web or use in phishing attacks.

6. Logic bombs

Logic bombs **trigger at a specific time or when a target has been met**. This target could be something completely arbitrary such as sending 500 emails. Or it could be targeted at business operations.

When the trigger point arrives, the logic bomb "explodes". The result could be the release of a worm or virus, with unpredictable consequences.

7. Pharming

Pharming **implants software on target devices to exploit DNS protocol vulnerabilities**. Attackers can then automatically redirect targeted web users to fake websites or downloads.

Pharming can also directly target unsecured DNS servers – redirecting network users to unsafe destinations.

Viruses

Viruses are similar to malware, but with one difference: they are **created specifically to propagate and spread as widely as possible**.
Viruses are the most common form of digital threat and can spread in numerous ways. Infected emails, messaging services, website downloads, and even infected USB sticks are all potential vectors.
Most computer viruses require a host file to spread. Unfortunately, this commonly targets popular formats like .doc, .exe, or .xml files – all formats that can appear legitimate when disguised by skilled attackers.

Worms

Worms are similar to computer viruses but **do not require a host file to replicate themselves**. They can often infiltrate devices without being detected, and when worms infest networks, they are difficult to remove.
Worms generally also spread more quickly than viruses. For instance, they may be designed to exploit a specific security vulnerability in a Windows release. In that case, the worm could replicate automatically from system to system if that vulnerability is present.

DDoS Attacks

A distributed denial of service (DDoS) attack leverages a botnet controlled by the attacker, which may consist of thousands or millions of machines, to flood networks with fake traffic.

Sometimes, the goal of a DDoS attack is to distract IT and security teams, while attackers are conducting a primary attack.

Large-scale DDoS attacks are impossible to withstand using on-premises security tools, and the most effective defense is third-party DDoS mitigation solutions that operate at cloud scale.

Botnets

Botnets are **groups of devices infected with malicious agents**. These devices are linked together, allowing attackers to control them remotely. Affected devices may not show any noticeable changes. But when used in tandem, thousands of bots can cause havoc on internal networks and the wider internet.

Most importantly, botnets are responsible for crippling Distributed Denial of Service (DDoS) attacks. Controllers often sell their services to attackers via DDoS-for-hire websites. These criminals then mount DDoS attacks, flooding targeted websites with data and potentially destroying their ability to function.

Botnets are closely associated with IoT devices that are often poorly configured, leaving them wide open for attackers.

Phishing and social engineering

Phishing involves sending fraudulent emails that persuade recipients to click on embedded links or file attachments. When recipients click them,

these links redirect to malicious content. This content could be anything from malware downloads to fake eCommerce portals.

The results are almost always dangerous for targeted organizations, with the average cost of phishing incidents amounting to $14.8 million per company.

Phishing is a flexible attack method with multiple strategies. Common varieties include:

1. Spear phishing

Phishers create detailed profiles of targets via malware or surveillance and use this information to write emails tailored to that individual.

2. Whaling

Attackers target high-level executives with broad security clearances and valuable contact information.

3. Vishing

Vishing is a mixture of email phishing and voice contact. Attackers may use hacked Voice-over-IP tools to imitate legitimate contacts, persuading targets to hand over sensitive information.

4. Smishing

Attackers use SMS messages to send phishing attacks. Attackers closely copy trusted sources and employ carefully chosen urgent language to make targets click embedded links.

5. Spam

The oldest phishing technique around. Spamming involves sending large amounts of mail with a low success rate but high value when targets respond.

Social Engineering

Social engineering attacks rely on manipulating human emotion to gain unauthorized network access. Attackers send messages that arouse curiosity, fear, or other emotions, and trick the user into deploying malware or divulging their network credentials. Common types of social engineering attacks include phishing, baiting, tailgating, and pretexting.

SQL injection attacks

In SQL injection attacks, **criminals target poorly configured search boxes on otherwise legitimate websites**. By entering malicious code, attackers can harvest information entered into those search fields, providing valuable data for social engineering assaults.

Physical sabotage and surveillance

Network security strategies also need to take into account physical threats. For instance, attackers could employ "shoulder-surfing" techniques, looking over the shoulder of employees in public wifi locations to glean valuable information.

There have also been examples of tailgating, where attackers gain access to offices and server hubs by following credentialed staff through security gates. Dumpster diving to obtain personal information is even a possibility.

Any information could be valuable to phishers mounting social engineering attacks. Companies should shred documents and use professional waste management partners to minimize the risk of data breaches.

Third-Party Vendors

Most organizations make use of third-party vendors, and commonly give these vendors access to critical systems. Several global security incidents were due to compromise of high-profile suppliers, which were used by some of the world’s leading organizations.

It is critical for organizations to establish a third-party risk management program. As part of this program, they should gain visibility over their suppliers’ security practices, and limit supplier privileges to the minimum possible.

Man-in-the-Middle attacks

MITM attacks occur when attackers **hijack connections between network devices or between a network and external devices**. By doing so, attackers can eavesdrop on traffic, extracting data transfers and information that can be used in social engineering attacks or sold to third-parties.

While they are commonly associated with remote working, MITM attacks can occur in any situation where devices interact via log-in portals. This makes secure Single Sign On (SSO) systems and network encryption essential.

Blended threats

The list of network threats above is highly simplified. In reality, many network security threats involve multiple attack methods to achieve their aims.

For example, the WannaCry network attacks in 2017 exploited a known vulnerability, ransomware demanding payment, and a worm that sought the same exploit on connected systems. This method infected 10,000 devices per hour at peak activity – showing how rapidly global threats can emerge.

Insider Threats

Insider threats might be malicious insiders motivated by vengeance or financial gain, compromised accounts, or negligent insiders who violate security policies. Insider threats are difficult to detect with traditional security tools, and because insiders have privileged access to sensitive systems, can be very dangerous. A key strategy for combating insider threats is zero trust security, which ensures every user has least privileges, and continuously verifies and authenticates all connection requests.

Advanced Persistent Threats (APT)

APTs are organized attackers, sometimes operated by groups of hackers, who launch sophisticated, highly evasive attacks against an organization.

APTs typically use multi-stage attacks with several attack vectors (such as social engineering, malware, and vulnerability exploitation) to penetrate a network, get around security defenses, and avoid detection. They might dwell in the network for months or years, slowly gaining access to valuable assets and stealing sensitive data.

How to identify network security vulnerabilities

1. Update software as quickly as possible

Zero-day exploits target software vulnerabilities in commonly used operating systems and apps, posing an immediate threat to users. The only way to safeguard your network assets against exploits is by **regularly patching software when updates become available**. Pay attention to End of Life dates. For instance, Windows 7 stopped receiving updates in January 2020, leaving users unprotected. And make sure employees are aware of the need to source updates from trusted websites.

2. Ensure complete network visibility

Network visibility allows security teams to track user behavior, picking up evidence of insider network threats and external infiltration before it becomes a critical danger.

Map every device connected to the network, including remote work laptops, smartphones, and IoT devices. And put in place monitoring systems to ensure that only privileged users have access to sensitive data or apps.

3. Secure your perimeter

Install perimeter protections like firewalls, Virtual Private Network (VPN) encryption, and access management systems such as Multi-Factor Authentication (MFA) or secure passwords.

With a secure network edge, you can be confident that any unusual traffic or user behavior is the product of malicious threats. Edge protection also prevents access for many attackers, providing a robust first line of defense.

4. Create deep security protection with Software Defined Perimeter (SDP) tools

Many network perimeters now reach deep into the Cloud. Remote working also constantly changes the threat surface, making traditional perimeter network security less effective.

Cloud-adapted network security tools like SDP **create encrypted bubbles around every user**, following them as they use third-party software, on-premises servers, and remote devices. Users can only access resources according to strict permission settings, and network segmentation means that lateral movement across the network is tightly limited.

SDP provides protection but also makes detecting threats to Cloud infrastructure easier. Security teams can monitor users closely, and any attempts to breach security policies will appear immediately.

5. Focus on physical network security

Companies need **policies to detect and neutralize physical threats** to network infrastructure and data. Security measures could include

surveillance cameras and sensors to protect servers, alongside access management tools like biometric or card scanning.

6. Use antivirus and anti-malware tools

Security teams should **equip all network devices with tools to scan for viruses and malware**. Security policies should include an authorized set of tools for users to install. These tools should be capable of detecting threats, and staff training should cover how to use them effectively.

7. Train staff to be vigilant

The human side of threat detection is also critical. **Staff must be aware of the dangers** posed by phishing and social engineering. They should know how to use email safely, and avoid dangerous remote working practices such as using unsecured public wifi or improperly secured mobile devices.

Employees can flag potential phishing strategies or holes in network security, and a well-trained, knowledgeable workforce is a strong guarantee against insider threats.

8. Actively detect DDoS attacks

DDoS attacks are relatively simple to **detect via packet monitoring software tool**s. Track DNS Request, DNS Response, Transmission Control Protocol Synchronize (TCP-SYN), User Datagram Protocol

(UDP), and Internet Control Message Protocol (ICMP) packets. Sudden spikes in any packet variant should alert security teams to potential attacks.

Types of Network Security Solutions

To protect against these threats, organizations use a variety of strategies, including defensive tools like next generation firewalls (NGFW), network segmentation which can isolate sensitive resources and prevent lateral movement, and incident response processes that enable rapid and effective response when attacks occur.

Zero trust, next generation firewalls (NGFW), and advanced threat detection solutions like XDR, can all help mitigate the APT threat.

There is no one approach to address all the critical threats presented above. However, the following network security practices can help prevent many of these threats, and help detect and mitigate them if an attack occurs.

Use a Next-Generation Firewall (NGFW)

Traditional firewalls inspect the state of network traffic, blocking or allowing traffic according to rules and filters defined by the administrator. NGFWs provide all the functionalities of a regular

firewall and more, enabling deep packet inspection (DPI) and blocking application-based threats.

For a firewall to qualify as a next-generation firewall (according to the Gartner definition), it must provide:

- Stateful inspection and other standard firewall functionalities
- Threat intelligence from various sources
- Application control and visibility to identify and block applications that present a risk
- An intrusion prevention system
- Adaptable capabilities to handle evolving cyber threats
- Upgrade paths for future threat intelligence feeds

Implement Network Segmentation and Segregation Strategies

Managing security for a large unsegmented network can be a complex task. Such tasks might include defining firewall rules and successfully handling traffic flow.

You can make management easier by segmenting your network into small chunks and creating different trust zones. This approach can also ensure networks are isolated if a security incident occurs, limiting the impact and risk of a network intrusion.

An unsegmented network presents attackers a greater attack surface. Attackers can then move laterally through the network and access business-critical information. A breach like this can bypass detection in a large scale network. Enforcing network segregation and segmentation gives your organization control over how traffic travels within your environment.

Conduct Third-Party Vendor Assessment

In some cases, you may have to work with third-party contractors. When you give third-party vendors access to your organization's network, it affects the security of your organization. In essence, your network is only as secure as your vendors.

Ensure you evaluate the security posture of any third-party vendors according to the level of access they need. Select vendors with strong security practices and appropriate compliance certifications, and be sure to revoke access as soon as a contractor is no longer working on your systems.

Establish an Incident Management Plan

An incident management plan guides you through the entire process of cyber incident management, from the time of the incident through to returning to normal operations. It defines roles and responsibilities, establishes procedures and communication

channels, and establishes an organizational structure for rapid response to incidents.

The incident response process is initiated when a security breach is identified via network security monitoring. The incident response team escalates the incident to the right teams and efficiently resolves the incident. After resolving the situation, the next step is to restore and recover systems to their correct functioning. A business continuity / disaster recovery (BC/DR) plan can help ensure the availability of your network and related systems even in case of a disaster or severe cyberattack.

Understand network security threats and minimize vulnerabilities

Every network is vulnerable to cyberattacks and insider threats. A single poorly configured device can bring poorly designed networks down, while the stolen credentials of a single employee can be used to extract millions of dollars worth of data. That's why network security is absolutely crucial.

Take action to plug network vulnerabilities and counter malware, phishing, viruses, and physical network threats. Investment in prevention always outweighs the cost of failure.

References:

https://www.catonetworks.com/network-security/network-security-protocols/#

https://www.cloudflare.com/learning/network-layer/what-is-the-network-layer/#

https://www.cisco.com/c/en/us/products/security/what-is-network-security.html

https://nordlayer.com/learn/network-security/threats/

https://www.infosecinstitute.com/